Penetration Test Report

Pentest Blackbox ITSEC ASIA

Prepared for ITSEC ASIA

Document version	1.692
Report date	2026-05-03
Classification	CONFIDENTIAL
Methodology	PTES, OWASP WSTG v4.2, OWASP API Top 10 (2023), NIST SP 800-115
Engagement window	2026-05-03 to 2026-05-03
Authoring firm	SentinelScan Greybox Team

1. Document Control & Revision History

Revision history

Version	Date	Author	Notes
1.692	2026-05-03	SentinelScan	Initial release

2. Executive Summary

SentinelScan executed a greybox penetration test against ITSEC ASIA's in-scope assets. Across 5 confirmed findings, we identified 0 critical, 0 high, 5 medium, and 0 low severity issues. The most material risks relate to Reconnaissance, XSS, Information Disclosure.

The risk posture chart below summarizes the distribution of confirmed findings by severity band. Critical and High items must be remediated within the timelines defined by the customer's vulnerability management policy (typically 7 and 30 days respectively).

Key recommendations

- Apply context-aware output encoding an
- Suppress or sanitize the `server` header
- Inventory and harden every public DNS r

3. Scope & Rules of Engagement

Engagement	Pentest Blackbox ITSEC ASIA
Client	ITSEC ASIA
Classification	CONFIDENTIAL
Web targets	https://itsec.asia/
API base URL	(none)

Rules of engagement

Greybox engagement. No destructive payloads, no DoS testing. Scanner identifie
SentinelScan/1.0`. Findings reported within 24h of confirmation.

4. Methodology

Testing followed a hybrid greybox approach combining authenticated active scanning, passive analysis of provided artefacts (source code, OpenAPI specifications, infrastructure-as-code), and manual exploitation of high-impact findings. Coverage maps to the following authoritative methodologies:

- PTES (Penetration Testing Execution Standard) — phases: pre-engagement, intelligence gathering, threat modeling, vulnerability analysis, exploitation, post-exploitation (identification only), reporting.
- OWASP Web Security Testing Guide v4.2 — 100+ test cases across information gathering, configuration, authentication, session management, authorization, input validation, error handling, cryptography, business logic, client-side and API testing.
- OWASP API Security Top 10 (2023) — BOLA, broken authentication, BFLA, mass assignment, security misconfiguration, etc.
- OWASP ASVS L1–L3 — verification controls applied selectively to in-scope components.
- NIST SP 800-115 — technical assessment guide for planning, executing and reporting.
- CIS Benchmarks — for cloud and infrastructure baseline comparison.
- MITRE ATT&CK — each finding is mapped to a relevant adversary technique where applicable.

5. Risk Rating Methodology (CVSS v3.1)

Findings are scored using the Common Vulnerability Scoring System v3.1 base metric group. Each finding lists a CVSS vector composed of attack vector (AV), attack complexity (AC), privileges required (PR), user interaction (UI), scope (S), and the confidentiality (C) / integrity (I) / availability (A) impact metrics. Severity bands follow the FIRST mapping:

Severity	CVSS Range	Customer SLA
Critical	9.0 – 10.0	Patch within 7 days
High	7.0 – 8.9	Patch within 30 days
Medium	4.0 – 6.9	Patch within 60 days
Low	0.1 – 3.9	Patch in next quarterly cycle
None	0.0	Informational

6. Summary of Findings

#	Severity	CVSS	Title	Asset
1	Medium	6.1	Reflected Cross-Site Scripting (XSS) via `q` parameter	https://itsec.asia/
2	Medium	5.3	Server fingerprinting via `server` header	https://itsec.asia/
3	Medium	5.3	Subdomain www.itsec.asia resolves and is in scope	www.itsec.asia
4	Medium	5.3	Subdomain admin.itsec.asia resolves and is in scope	admin.itsec.asia
5	Medium	5.3	Subdomain mail.itsec.asia resolves and is in scope	mail.itsec.asia

6.1 Severity × Asset Heatmap

The heatmap visualises how confirmed findings cluster across in-scope assets. Cells are coloured by severity band; the number indicates the count of findings of that severity on that asset. Use this view to prioritise asset-level remediation campaigns.

Asset	Critical	High	Medium	Low	None
https://itsec.asia/	0	0	2	0	0
www.itsec.asia	0	0	1	0	0
admin.itsec.asia	0	0	1	0	0
mail.itsec.asia	0	0	1	0	0

7. Detailed Findings

F-001 Reflected Cross-Site Scripting (XSS) via `q` parameter

MEDIUM
6.1 CVSS v3.1

CVSS Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

Affected asset	https://itsec.asia/
Module	web
Category	XSS
CWE	CWE-79
OWASP	A03:2021 Injection
MITRE ATT&CK	T1059.007
Likelihood	High

Description

The application reflected the unsanitized `q` query parameter directly into the HTML response
onload=...>` payload. Any attacker-controlled URL can execute JavaScript in a victim's browser.

Technical details

Sentinel `ssXSS_cfq17act` was reflected unencoded in the response body.

Proof of Concept

```
$ curl 'https://itsec.asia/?q=%3Csvg%2Fonload%3DssXSS_cfq17act%3E'
# response contains: <svg/onload=ssXSS_cfq17act>
```

Impact

Session hijacking, credential theft, defacement, arbitrary action in the victim's session.

Recommendation

Short term — Apply context-aware output encoding and a strict Content-Security-Policy.

Long term — Encode reflected user input for the appropriate sink (HTML, attribute, JS, URL). Use a templating engine that auto-escapes. Add a strong CSP (`script-src 'self'`).

References

https://owasp.org/www-community/attacks/xss/

F-002 Server fingerprinting via `server` header

MEDIUM
5.3 CVSS v3.1

CVSS Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Affected asset	https://itsec.asia/
Module	headers
Category	Information Disclosure
CWE	CWE-200
OWASP	A05:2021 Security Misconfiguration
MITRE ATT&CK	T1592.004
Likelihood	Medium

Description

The server discloses technology and version information via the `server` header (`ITSEC ASIA
to map exploits to known CVEs.

Technical details

Header `server: ITSEC ASIA` returned by the server reveals stack details.

Proof of Concept

```
$ curl -sI https://itsec.asia/ | grep -i server
```

Impact

Enables targeted exploitation by narrowing CVE search space.

Recommendation

Short term — Suppress or sanitize the `server` header at the reverse-proxy or application layer.

Long term — Remove the header in all environments, or replace it with a static, non-versioned value. Consider failing CI if these headers reappear.

References

https://owasp.org/www-community/attacks/Server-Side_Request_Forgery

F-003 Subdomain www.itsec.asia resolves and is in scope

MEDIUM
5.3 CVSS v3.1

CVSS Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Affected asset	www.itsec.asia
Module	dns
Category	Reconnaissance
CWE	CWE-200
OWASP	A01:2021 Broken Access Control
Likelihood	Low

Description

Host `www.itsec.asia` was discovered via subdomain enumeration of `itsec.asia`. It resol
Confirm whether it is intentionally exposed.

Technical details

A: 34.8.138.176; CNAME: itsec.asia

Impact

Unmanaged subdomains can expose deprecated services, staging environments, or shadow IT

Recommendation

Short term — Inventory and harden every public DNS record; remove unused entries.

References

https://owasp.org/www-community/Subdomain_Takeover

F-004 Subdomain admin.itsec.asia resolves and is in scope

MEDIUM
5.3 CVSS v3.1

CVSS Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Affected asset	admin.itsec.asia
Module	dns
Category	Reconnaissance
CWE	CWE-200
OWASP	A01:2021 Broken Access Control
Likelihood	Low

Description

Host `admin.itsec.asia` was discovered via subdomain enumeration of `itsec.asia`. It resol
Confirm whether it is intentionally exposed.

Technical details

A: 166.62.28.88; CNAME: n/a

Impact

Unmanaged subdomains can expose deprecated services, staging environments, or shadow IT

Recommendation

Short term — Inventory and harden every public DNS record; remove unused entries.

References

https://owasp.org/www-community/Subdomain_Takeover

F-005 Subdomain mail.itsec.asia resolves and is in scope

MEDIUM
5.3 CVSS v3.1

CVSS Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Affected asset	mail.itsec.asia
Module	dns
Category	Reconnaissance
CWE	CWE-200
OWASP	A01:2021 Broken Access Control
Likelihood	Low

Description

Host `mail.itsec.asia` was discovered via subdomain enumeration of `itsec.asia`. It resolv
Confirm whether it is intentionally exposed.

Technical details

A: 166.62.28.88; CNAME: n/a

Impact

Unmanaged subdomains can expose deprecated services, staging environments, or shadow IT

Recommendation

Short term — Inventory and harden every public DNS record; remove unused entries.

References

https://owasp.org/www-community/Subdomain_Takeover

8. Remediation Roadmap

The roadmap below sequences remediation work by risk × effort. Items at the top should be addressed first.

Wave	Severity	Theme	Action
Wave 1	Medium	XSS	1 finding — Apply context-aware output encoding and a strict Content Security Policy
Wave 2	Medium	Information Disclosure	1 finding — Suppress or sanitize the `server` header at the reverse-proxy or application layer.
Wave 3	Medium	Reconnaissance	3 findings — Inventory and harden every public DNS record; remove unused entries.

9. Appendix A — Tools & Methodology

The following tools and engines were orchestrated by the SentinelScan platform during this engagement. The platform normalizes output from each engine into a common finding schema so that severities and remediations are consistent regardless of the producing tool.

- OWASP ZAP / Nuclei templates — web active scanning (XSS, SQLi, SSRF, IDOR).
- sslyze-style TLS probing — protocol, cipher and certificate hygiene.
- Nmap — service / version discovery for in-scope hosts.
- Trivy / Checkov — IaC and cloud configuration analysis.
- Semgrep — source-level SAST with curated ruleset.
- OSV / Trivy — software composition analysis on declared dependencies.
- Internal hybrid orchestrator — header / CORS / OpenAPI fuzzing and rate-limit probes.

9. Appendix B — Glossary

BOLA Broken Object Level Authorization — a server fails to verify the caller is allowed to access the requested object identifier.

BFLA Broken Function Level Authorization — a server fails to enforce role / function restrictions on an endpoint.

CSP Content Security Policy — a browser-enforced policy restricting which sources may serve scripts, styles and other resources.

CVE Common Vulnerabilities and Exposures — public catalogue of known vulnerabilities.

CVSS Common Vulnerability Scoring System — vendor-neutral severity rating system.

CWE Common Weakness Enumeration — catalogue of software weakness types.

HSTS HTTP Strict Transport Security — header that forces browsers to use HTTPS.

MITRE ATT&CK Knowledge base of adversary tactics and techniques mapped to real-world incidents.

PoC Proof of

Concept — minimal artefact demonstrating a vulnerability.

SAST Static Application Security Testing — source-level analysis.

SCA Software Composition Analysis — detection of vulnerable third-party packages.

SSRF Server-Side Request Forgery — server can be coerced to make HTTP requests on the attacker's behalf.